

PART 16 OF 18

Enterprise AI Reference Architectures

Production-Grade Architectures for Single-Agent, Multi-Agent, Finance, HR, Coding, DevOps, Customer Support, Regulated, and Air-Gapped Environments

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

16.1 Architecture Taxonomy and Selection Criteria

The following reference architectures address the most common enterprise AI agent deployment patterns. Each architecture is designed to be production-deployable, not just conceptual. Selection criteria for each pattern are provided to help architects choose the appropriate baseline for their use case.

Pattern 1: Single-Agent Internal Assistant

Selection Criteria: < 5 integrated systems; single business unit; < 500 users; low-medium data sensitivity

Pattern 2: Multi-Agent Workflow Platform

Selection Criteria: > 5 integrated systems; cross-functional workflows; complex task decomposition; medium-high data sensitivity

Pattern 3: Enterprise Agent Platform

Selection Criteria: Platform serving multiple BUs; diverse agent types; high scale; governance requirements

Pattern 4: Highly Regulated Environment

Selection Criteria: Financial services, healthcare, government; strict compliance; audit requirements; adversarial threat model

Pattern 5: Air-Gapped Deployment

Selection Criteria: Classified environments; no internet connectivity; on-premises only; maximum security controls

16.2 Pattern 1: Single-Agent Internal Assistant

16.2.1 Component Architecture

Component	Technology	Security Config
Agent Framework	LangGraph / Anthropic SDK	Checkpoint enabled; interrupt on risk threshold
LLM Endpoint	Anthropic API / AWS Bedrock	Private endpoint; mTLS; no model logging (data residency)
Identity	SPIFFE SVID (short-lived)	Auto-rotate every 1 hour; revocation on session end
Authorization	OPA sidecar	Hard constraints + contextual ABAC; < 5ms P99 latency
Tool Execution	Isolated Lambda / Cloud Run	Per-invocation container; VPC isolation; secrets from Vault

Component	Technology	Security Config
Memory	PostgreSQL + pgvector	Encrypted at rest (AES-256); access control by session ID; RLS
Observability	Langfuse + OTel Collector	Reasoning traces encrypted; PII redaction pipeline
Human Approval	Slack workflow integration	SLA: 5 min for high-risk; 15 min for medium-risk
Audit Store	Immutable S3 / CloudWatch Logs	Object Lock (WORM); 3-year retention; encrypted

16.3 Pattern 2: Multi-Agent Workflow Platform

16.3.1 Orchestration Architecture

Multi-agent workflow platforms require additional security architecture around inter-agent trust, shared resource governance, and workflow-level risk assessment. The orchestrator is the highest-risk component because it controls multiple agents and has broad visibility into workflow state.

Component	Technology	Security Config
Orchestrator	LangGraph multi-agent / AutoGen	Minimal orchestrator permissions; cannot elevate sub-agent trust
Sub-Agent Pool	Specialized agents per function	Each has independent policy enforcement; own identity
Inter-Agent Bus	Kafka / Google Pub/Sub	mTLS; message signing; agent identity in message header
Shared Memory	Redis (ephemeral) + PostgreSQL (persistent)	Namespace isolation; agent-scoped read/write; no cross-namespace
Tool Registry	Custom registry service	Registry as single source of truth; agents cannot bypass
Workflow Governance	Temporal.io	Workflow audit log; step-level policy enforcement hooks
Risk Aggregation	Custom risk service	Aggregate risk across all agents in workflow; workflow-level circuit breaker
Cross-Agent Monitoring	Behavioral analytics with cross-correlation	Detect collusion patterns; correlated anomaly detection

16.4 Vertical-Specific Architectures

16.4.1 Finance Agent Architecture

Finance agents require the most stringent security controls due to the combination of high-value targets, strict regulatory requirements (SOX, PCI DSS, Basel III), and the potential for direct financial loss from unauthorized

actions.

Financial Action Limits

Every financial action has a hard dollar limit enforced by the policy engine; limits defined by transaction type and require human approval above threshold

Four-Eyes Principle

All financial transactions above defined thresholds require approval from two separate humans, implemented as dual-signature in the approval workflow

Real-Time Fraud Detection

Every agent-initiated financial transaction submitted to fraud detection service before execution; block and alert if fraud score > threshold

Complete Audit Trail

Every financial action retains: agent identity, delegating user, business justification, full action parameters, approval chain, timestamp. Retained 7 years minimum.

Market Data Isolation

Agent access to market data through rate-limited, type-safe proxy; raw websocket access prohibited

Sandbox Testing

All new finance agent capabilities must pass identical scenarios in production-mirrored sandbox before deployment

16.4.2 Healthcare Agent Architecture

PHI Access Controls

All PHI access requires: patient consent check, treating relationship verification, minimum necessary principle, BAA compliance for agent framework provider

De-identification Pipeline

PHI de-identified before entering model context using Safe Harbor or Expert Determination method; re-identification prohibited

Prescriptive Action Restrictions

Agents cannot prescribe medications, diagnose conditions, or recommend treatments; these actions require human clinician review

Audit for HIPAA

Full audit trail of all PHI access; access log includes reason for access; available for patient request within 60 days

16.4.3 Highly Regulated Environment Architecture

For highly regulated environments (financial services, healthcare, government), the baseline security architecture is supplemented with:

- **Hardware Security Modules (HSMs):** All cryptographic operations performed by HSMs; keys never leave HSM boundary
- **Confidential Computing:** Agent execution in Intel TDX or AMD SEV-SNP confidential VMs; memory encrypted even from cloud provider
- **Zero-Knowledge Audit:** Audit records structured to provide compliance evidence without exposing sensitive agent context
- **Formal Approval Workflows:** All high-risk agent deployments require formal risk acceptance sign-off at SVP level minimum
- **Regulatory Sandbox:** All new agent capabilities tested in regulatory sandbox environment mirroring production controls
- **Compliance Automated Reporting:** Monthly automated compliance reports generated from telemetry data; no manual data collection

16.5 Air-Gapped Deployment Architecture

Air-gapped deployments require all AI capabilities—models, tools, knowledge bases, and governance services—to operate without internet connectivity. This creates specific challenges for model currency, threat intelligence updates, and certificate management.

Challenge	Air-Gapped Solution
Model access	On-premises model serving (Ollama, vLLM, llama.cpp) with locally hosted open-weight models
Model updates	Manual update process with offline verification; cryptographically signed model packages delivered via secure physical media
Threat intelligence	Periodic offline updates to MITRE ATLAS signatures; manual review of security advisories
Certificate management	Internal PKI with offline root CA; online intermediate CAs within the air-gapped network
Tool connectivity	All tools must operate against internal systems only; external API proxy with data diode for approved one-way feeds
Observability	Internal ELK stack or Grafana; no external telemetry export; local behavioral analytics models
Identity federation	Internal SPIFFE/SPIRE deployment with no external trust federation; local identity broker

Challenge	Air-Gapped Solution
Policy updates	Policy changes go through formal change management; digitally signed policy packages